

Sec 10. Defensive Security

A. Defensive Security Intro

Task 1 - Introduction to Defensive Security

Defensive security, **known as the blue team**, is used to prepare and proactively protect an organisation's IT infrastructure. It is concerned with two main tasks:

1. Preventing intrusions from occurring
2. Detecting intrusions when they occur and responding properly

| Which team focuses on defensive security? Blue Team

Task 2 - Exploring the SOC

A Security Operations Centre (SOC) is a team of cyber security professionals that monitors the network and its systems to detect malicious cyber security events. Some of the main areas of interest for a SOC are:

Trends & Vulnerability Awareness: Keeping up to date with the latest trends and vulnerabilities in the industry is an essential skill to help understand the risks an organisation faces.

Policy Violations: A security policy is a set of rules that outline how an organisation's assets are to be used and protected. The SOC team monitors for adherence to these policies.

Unauthorised & Illegal Activity: The SOC team establishes a baseline of acceptable behaviour and activity. Any deviation from this baseline is investigated. Illegal activity exposes the organisation to higher risk.

Intrusion & Breach Detection: No matter how well protected an organisation is, there is always a risk of a breach. The SOC team is responsible for detecting and responding to these breaches.

| What would you call a team of cyber security professionals that monitors a network and its systems for malicious events? Security Operations Centre

Task 3 - Digital Forensics

Digital forensics is the application of traditional forensic science processes to digital devices. Digital forensics is used to preserve and analyse digital evidence to aid in the investigation of incidents, such as a breach. This may involve looking at information from:

File System: Analysing a low-level copy of a system's storage reveals much information, such as installed programs, created, partially overwritten and deleted files.

System Memory: If an attacker runs a malicious program within the memory without saving it to the disk, the memory can be analysed to uncover details about how the program operates.

System Logs: Log files provide plenty of information about what happened on a system. Even if the attacker tries to clear their traces, some traces will remain.

Network Logs: Logs of the network traffic that have traversed a network would help answer more questions about whether an attack is occurring and what it entails.

An attacker deploys a piece of malicious code that does not save to the disk. What digital forensics technique would we use in this instance? System Memory

Task 4 - Incident Response

Incident Response is how organisations manage security events such as breaches, data leaks and cyber attacks. An incident response process is a defined set of stages to minimise damage, contain the threat and recover fast.

Preparation: Creating the necessary resources and frameworks to handle an incident. This includes creating incident response teams, infrastructure to support in the incident response process, as well anything to help prevent the incidents, such as providing phishing awareness training.

Detection & Analysis: Using tooling and processes to detect incidents and assess their scope (reach) and severity. Logs can be analysed for suspicious events.

Containment, Eradication, and Recovery: Limiting the impact of the incident, such as preventing a virus from spreading and eliminate the cause and restore affected systems.

Post-Incident Activity: Review the incident overall, how it was handled and could've been prevented. What were the learning points throughout the process? Do we need to provide further cyber awareness training?

What phase of the incident response process involves providing "cyber awareness" training to employees? Preparation

B. SOC Fundamentals

Task 1 - Introduction to SOC

A **SOC (Security Operations Center)** is a dedicated facility operated by a specialized security team. This team aims to continuously monitor an organization's network and resources and identify suspicious activity to prevent damage. This team works 24 hours a day, seven days a week.

What does the term SOC stand for? Security Operations Center

Task 2 - Purpose and Components

The main focus of the SOC team is to keep **Detection** and **Response** intact. The SOC team has some resources available in the form of security solutions that help them achieve this. These solutions integrate the whole company's network and all the systems to monitor them from one centralized location. Continuous monitoring is required to detect and respond to any security incident.

Detection

- **Detect vulnerabilities:** A vulnerability is a weakness that an attacker can exploit to carry out things beyond their permission level. A vulnerability might be discovered in any device's software (operating system and programs), such as a server or computer. For instance, the SOC might discover a set of MS Windows computers that must be patched against a specific published vulnerability. Strictly speaking, vulnerabilities are not necessarily the SOC's

responsibility; however, unfixed vulnerabilities affect the security level of the entire company.

- **Detect unauthorized activity:** Consider the case where an attacker discovered the username and password of one of the employees and used them to log in to the company system. It is crucial to detect this kind of unauthorized activity quickly before it causes any damage. Many clues, such as geographic location, can help us detect this.
- **Detect policy violations:** A security policy is a set of rules and procedures created to help protect a company against security threats and ensure compliance. What is considered a violation would vary from company to company; examples include downloading pirated media files and sending confidential company files insecurely.
- **Detect intrusions:** Intrusions refer to unauthorized access to systems and networks. One scenario would be an attacker successfully exploiting our web application. Another would be a user visiting a malicious site and getting their computer infected.

Response

- **Support with the incident response:** Once an incident is detected, certain steps are taken to respond to it. This response includes minimizing its impact and performing the root cause analysis of the incident. The SOC team also helps the incident response team carry out these steps.

There are three pillars of a SOC. With all these pillars, a SOC team becomes mature and efficiently detects and responds to different incidents. These pillars are **People**, **Process**, and **Technology**.

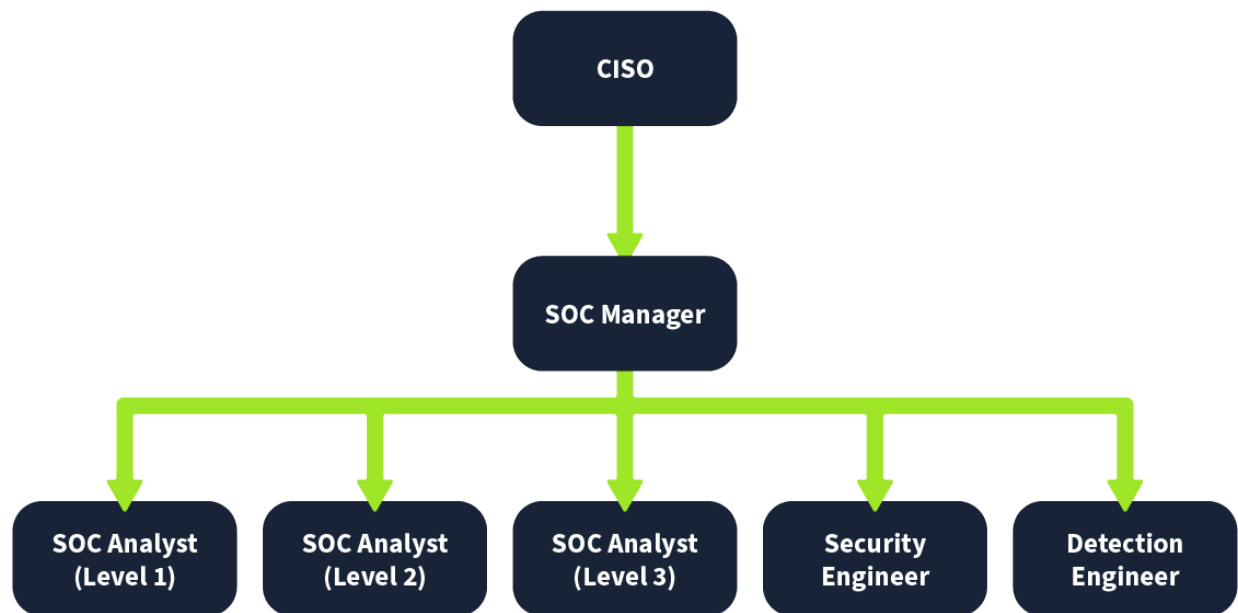
People, **Process**, and **Technology** coexist in a SOC environment. A team of professional individuals working on state-of-the-art security tools in the presence of proper processes is what makes a mature SOC environment.

Answer the questions below:

The SOC team discovers an unauthorized user is trying to log in to an account. Which capability of SOC is this? Detection
What are the three pillars of a SOC? People, Process, Technology

Task 3 - People

In a SOC, with security solutions in place without human intervention, you'll end up focusing on more irrelevant issues. There are always the **People** who help the security solution to identify truly harmful activities and enable a prompt response. The **People** are known as the SOC team. This team has the following roles and responsibilities.



- **SOC Analyst (Level 1):** Anything detected by the security solution would pass through these analysts first. These are the first responders to any detection. SOC Level 1 Analysts perform basic alert triage to determine if a specific detection is harmful. They also report these detections through proper channels.
- **SOC Analyst (Level 2):** While Level 1 does the first-level analysis, some detections may require deeper investigation. Level 2 Analysts help them dive deeper into the investigations and correlate the data from multiple data sources to perform a proper analysis.
- **SOC Analyst (Level 3):** Level 3 Analysts are experienced professionals who proactively look for any threat indicators and support in the incident response activities. The critical severity detection reported by Level 1 and Level 2 Analysts are often security incidents that need detailed responses, including

containment, eradication, and recovery. This is where Level 3 analysts' experience comes in handy.

- **Security Engineer:** All analysts work on security solutions. These solutions need deployment and configuration. Security Engineers deploy and configure these security solutions to ensure their smooth operation.
- **Detection Engineer:** Security rules are the logic built behind security solutions to detect harmful activities. Level 2 and 3 Analysts often create these rules, while the SOC team can sometimes also utilize the detection engineer role independently for this responsibility.
- **SOC Manager:** The SOC Manager manages the processes the SOC team follows and provides support. The SOC Manager also remains in contact with the organization's CISO (Chief Information Security Officer) to provide him with updates on the SOC team's current security posture and efforts.

Answer the questions below

Alert triage and reporting is the responsibility of? SOC Analyst (Level 1)

Which role in the SOC team allows you to work dedicatedly on establishing rules for alerting security solutions? Detection Engineer

Task 4 - Process

Each role has its own **Processes**, just as we saw the role of Level 1 SOC Analysts as the first responders to carry out alert triage and determine if it is harmful. Let's discuss some important processes involved in a SOC.

Alert Triage: The alert triage is the basis of the SOC team. The first response to any alert is to perform the triage. The triage is focused on analyzing the specific alert. This determines the severity of the alert and helps us prioritize it. The alert triage is all about answering the 5 Ws. What are these 5 Ws?

Following are some questions that need to be answered during the triage of an alert. **Alert:** Malware detected on Host: GEORGE PC

5 Ws	Answers
What?	A malicious file was detected on one of the hosts inside the organization's network.
When?	The file was detected at 13:20 on June 5, 2024.
Where?	The file was detected in the directory of the host: "GEORGE PC".
Who?	The file was detected for the user George.
Why?	After the investigation, it was found that the file was downloaded from a pirated software-selling website. The investigation with the user revealed that they downloaded the file as they wanted to use a software for free.

Reporting: The detected harmful alerts need to be escalated to higher-level analysts for a timely response and resolution. These alerts are escalated as tickets and assigned to the relevant people. The report should discuss all the 5 Ws along with a thorough analysis, and screenshots should be used as evidence of the activity.

Incident Response and Forensics: Sometimes, the reported detections point to highly malicious activities that are critical. In these scenarios, high-level teams initiate an incident response.

Answer the questions below

At the end of the investigation, the SOC team found that John had attempted to steal the system's data. Which 'W' from the 5 Ws does this answer? Who

The SOC team detected a large amount of data exfiltration. Which 'W' from the 5 Ws does this answer? What

Task 5 - Technology

The **Technology** portion in the SOC pillars refers to the security solutions. These security solutions efficiently minimize the SOC team's manual effort to detect and respond to threats.

- **SIEM:** Security Information and Event Management (SIEM) is a popular tool used in almost every SOC environment. This tool collects logs from various network devices, referred to as log sources. Detection rules are configured in the SIEM solution, which contains logic to identify suspicious activity.

The SIEM solution provides us with the detections after correlating them with multiple log sources and alerts us in case of a match with any of the rules. Modern SIEM solutions surpass this rule based detection analysis, providing us with user behavior analytics and threat intelligence capability. Machine learning algorithms support this to enhance the detection capabilities.

Note: The SIEM solution only provides the **Detection** capabilities in a SOC environment.

- **EDR:** Endpoint Detection and Response (EDR) provides the SOC team with detailed real-time and historical visibility of the devices' activities. It operates on the endpoint level and can carry out automated responses. EDR has extensive detection capabilities for endpoints, allowing you to investigate them in detail and respond with a few clicks.
- **Firewall:** A firewall functions purely for network security and acts as a barrier between your internal and external networks (such as the Internet). It monitors incoming and outgoing network traffic and filters any unauthorized traffic. The firewall also has some detection rules deployed, which help us identify and block suspicious traffic before it reaches the internal network.

Answer the questions below

Which security solution monitors the incoming and outgoing traffic of the network? Firewall

Do SIEM solutions primarily focus on detecting and alerting about security incidents? yea

C. Digital Forensics Fundamentals

Task 1 - Introduction to Digital Forensics

Forensics is the application of methods and procedures to investigate and solve crimes. The branch of forensics that investigates cyber crimes is known as **digital forensics**. **Cyber crime** is any criminal activity conducted on or using a digital device. Several tools and techniques are used to investigate digital devices

thoroughly after any crime to find and analyze evidence for necessary legal action. The following evidence was found on the digital devices:

- A digital map of the bank was found on the suspect's laptop, which they kept for planning the robbery.
- A document with the bank's entrance and escape routes was found on the suspect's hard drive.
- A document on the hard drive that listed all the bank's physical security controls. The suspect devised plans to bypass the security measures.
- Some media files, including photos and videos of the suspect's previous robberies, were inside the suspect's laptop.
- After conducting a thorough investigation of the suspect's mobile phone, some illegal chat groups and call records related to the bank robbery were also found.

| Which team was handed the case by law enforcement? digital forensics

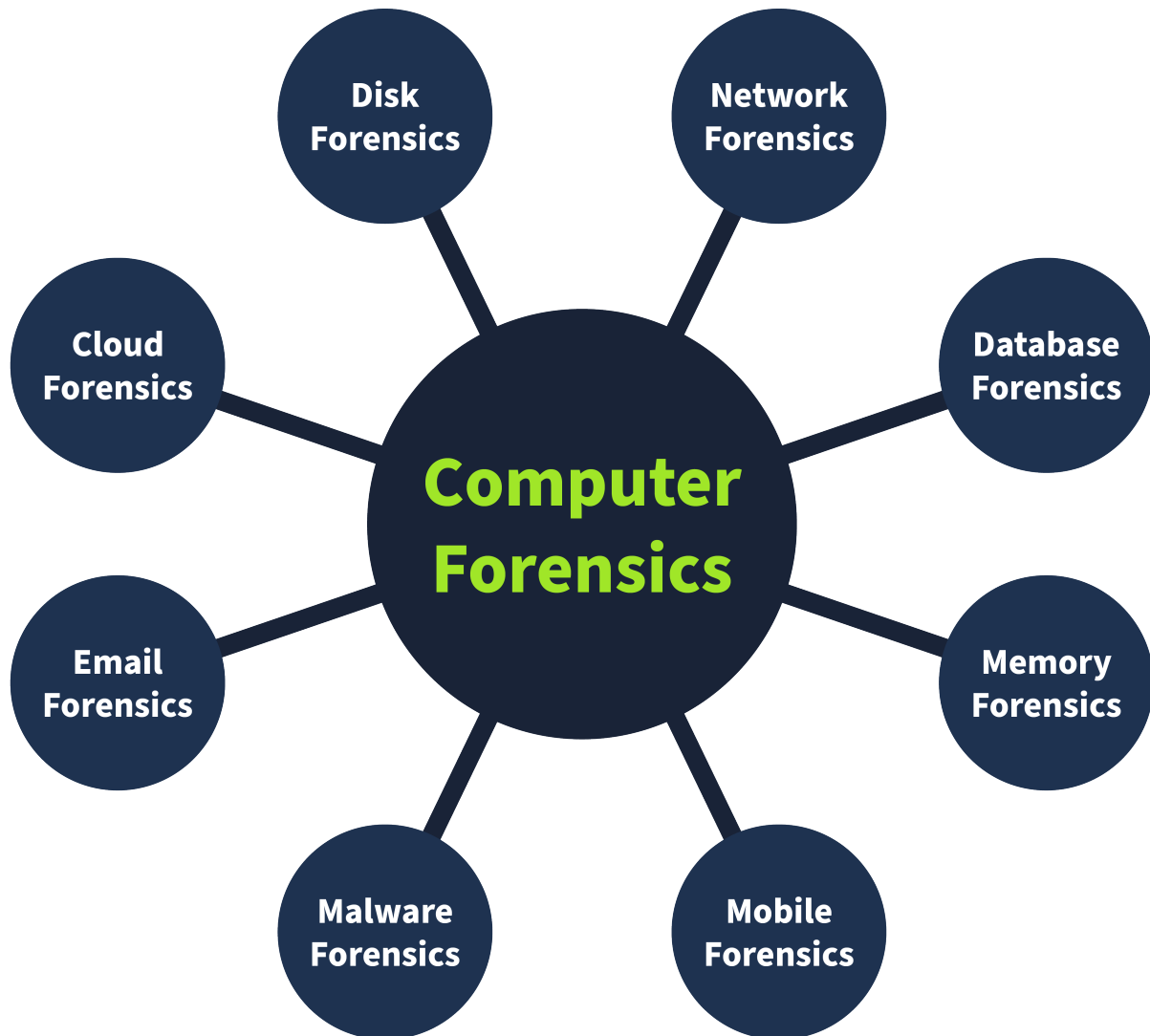
Task 2 - Digital Forensics Methodology

the National Institute of Standards and Technology (NIST) defines a general process for every case. The NIST works on defining frameworks for different areas of technology, including cyber security, where they introduce the process of digital forensics in four phases.

1. **Collection:** The first phase of digital forensics is data collection. Identifying all the devices from which the data can be collected is essential. Usually, an investigator can find personal computers, laptops, digital cameras, USBs, etc., on the crime scene. It is also necessary to ensure the original data is not tampered with while collecting the evidence and to maintain a proper document containing the collected items' details. We will also be discussing the evidence-acquisition procedures in the upcoming tasks.
2. **Examination:** The collected data may overwhelm investigators due to its size. This data usually needs to be filtered, and the data of interest needs to be extracted. For example, as an investigator, you collected all the media files from a digital camera on the crime scene. You may only require some of the

media as you are concerned with the media recorded on a specific date and time. So, in the examination phase, you would filter the media files of the required time and move them to the next phase. Similarly, you may only need the data of a specific user from a system containing numerous user accounts. The examination phase helps you filter this particular data for analysis.

3. **Analysis:** This is a critical phase. The investigators now have to analyze the data by correlating it with multiple pieces of evidence to draw conclusions. The analysis depends upon the case scenario and available data. The analysis aims to extract the activities relevant to the case chronologically.
4. **Reporting:** In the last phase of digital forensics, a detailed report is prepared. This report contains the investigation's methodology and detailed findings from the collected evidence. It may also contain recommendations. This report is presented to law enforcement and executive management. It is important to include executive summaries as part of the report, considering the level of understanding of all the receiving parties.



- **Computer forensics:** The most common type of digital forensics is computer forensics, which concerns investigating computers, the devices most commonly used in crimes.
- **Mobile forensics:** Mobile forensics involves investigating mobile devices and extracting evidence such as call records, text messages, GPS locations, and more.
- **Network forensics:** This area of forensics covers investigation beyond individual devices. It includes the whole network. The majority of the evidence found in networks is the network traffic logs.

- **Database forensics:** Many critical data is stored in dedicated databases. Database forensics investigates any intrusion into these databases that results in data modification or exfiltration.
- **Cloud forensics:** Cloud forensics is the type of forensics that involves investigating data stored on cloud infrastructure. This type of forensics sometimes gets tricky for the investigators as there is little evidence on cloud infrastructures.
- **Email forensics:** Email, the most common communication method between professionals, has become an important part of digital forensics. Emails are investigated to determine whether they are part of phishing or fraudulent campaigns.

Answer the questions below

Which phase of digital forensics is concerned with correlating the collected data to draw any conclusions from it? Analysis

Which phase of digital forensics is concerned with extracting the data of interest from the collected evidence? Examination

Task 3 - Evidence Acquisition

Acquiring evidence is a critical job. The forensics team must collect all the evidence securely without tampering with the original data. Evidence acquisition methods for digital devices depend on the type of digital device. However, some general practices must be followed while the evidence is acquired. Let's discuss some of the important ones.

Proper Authorization: The forensics team should obtain authorization from the relevant authorities before collecting any data. Evidence collected without prior approval may be deemed inadmissible in court. Forensic evidence contains private and sensitive data of an organization or individual. Proper authorization before collecting this data is essential for investigating according to the limits of the law.

Chain of Custody: Imagine that a team of investigators collects all the evidence from the crime scene, and some of the evidence goes missing after a few days, or there is any change in the evidence. No individual can be held accountable in this

scenario because there is no proper process for documenting the evidence owners. This problem can be solved by maintaining a chain of custody document. A chain of custody is a formal document containing all the details of the evidence. Some of the key details are listed below:

- Description of the evidence (name, type).
- Name of individuals who collected the evidence.
- Date and time of evidence collection.
- Storage location of each piece of evidence.
- Access times and the individual record who accessed the evidence.

Use of Write Blockers: Write blockers are an essential part of the digital forensics team's toolbox. Suppose you are collecting evidence from a suspect's hard drive and attaching the hard drive to the forensic workstation. While the collection occurs, some background tasks in the forensic workstation may alter the timestamps of the files on the hard drive. This can cause hindrances during the analysis, ultimately producing incorrect results. Suppose the data was collected from the hard drive using a write blocker instead in the same scenario. This time, the suspect's hard drive would remain in its original state as the write blocker can block any evidence alteration actions.

Answer the questions below

| Which tool is used to ensure data integrity during the collection? write blocker

| What is the name of the document that has all the details of the collected digital evidence? chain of custody

Task 4 - Windows Forensics

The most common types of evidence collected from crime scenes are desktop computers and laptops, as most criminal activity involves a personal system. These devices have different operating systems running on them. In this task, we will discuss the evidence acquisition and analysis of the Windows operating system, which is a very common operating system that has been investigated in several cases. As part of the data collection phase, forensic images of the Windows operating system are taken. These forensic images are bit-by-bit copies

of the whole operating system. Two different categories of forensic images are taken from a Windows operating system.

- **Disk image:** The disk image contains all the data present on the storage device of the system (HDD, SSD, etc.). This data is non-volatile, meaning that the disk data would survive even after a restart of the operating system. For example, all the files like media, documents, internet browsing history, and more.
- **Memory image:** The memory image contains the data inside the operating system's RAM. This memory is volatile, meaning the data will get lost after the system is powered off or restarted. For example, to capture open files, running processes, current network connections, etc., the memory image should be prioritized and taken first from the suspect's operating system; otherwise, any restart or shutdown of the system would result in all the volatile data getting deleted. While carrying out digital forensics on a Windows operating system, disk and memory images are very important to collect.

Let's discuss some popular tools used for disk and memory image acquisition and analysis of the Windows operating system.

FTK Imager: FTK Imager is a widely used tool for taking disk images of Windows operating systems. It offers a user-friendly graphical interface for creating the image in various formats. This tool can also analyze the contents of a disk image. It can be used for both acquisition and analysis purposes.

Autopsy: Autopsy is a popular open-source digital forensics platform. An investigator can import an acquired disk image into this tool, and the tool will conduct an extensive analysis of the image. It offers various features during image analysis, including keyword search, deleted file recovery, file metadata, extension mismatch detection, and many more.

Dumplt: Dumplt offers the utility of taking a memory image from a Windows operating system. This tool creates memory images using a command-line interface and a few commands. The memory image can also be taken in different formats.

Volatility: Volatility is a powerful open-source tool for analyzing memory images. It offers some extremely useful plugins. Each artifact can be analyzed using a

specific plugin. This tool supports various operating systems, including Windows, Linux, macOS, and Android.

Note: Various other tools are also used to acquire and analyze disk and memory images of the Windows operating system.

Answer the questions below

Which type of forensic image is taken to collect the volatile data from the operating system? Memory Image

Task 5 - Practical Example of Digital Forensics

We can try to read the metadata using the program `pdftinfo`. Pdftinfo displays various metadata related to a PDF file, such as title, subject, author, creator, and creation date. (The AttackBox already has `pdftinfo` installed; however, if you are using Kali Linux and don't have `pdftinfo` installed, you can install it using `sudo apt install poppler-utils`.) Consider the following example of using `pdftinfo DOCUMENT.pdf`:

Terminal

```
root@tryhackme:~# pdftinfo DOCUMENT.pdf
Creator:      Microsoft® Word for Office 365
Producer:     Microsoft® Word for Office 365
CreationDate: Wed Oct 10 21:47:53 2018 EEST
ModDate:      Wed Oct 10 21:47:53 2018 EEST
Tagged:       yes
UserProperties: no
Suspects:     no
Form:         none
JavaScript:   no
Pages:        20
Encrypted:    no
Page size:    595.32 x 841.92 pts (A4)
Page rot:     0
File size:    560362 bytes
```

```
Optimized:      no
PDF version:    1.7
```

The PDF metadata clearly shows that it was created using MS Word for Office 365 on October 10, 2018.

Photo EXIF Data: EXIF stands for Exchangeable Image File Format; it is a standard for saving metadata to image files. Whenever you take a photo with your smartphone or with your digital camera, plenty of information gets embedded in the image. The following are examples of metadata that can be found in the original digital images:

- Camera model / Smartphone model
- Date and time of image capture
- Photo settings such as focal length, aperture, shutter speed, and ISO settings

Because smartphones are equipped with a GPS sensor, finding GPS coordinates embedded in the image is highly probable. The GPS coordinates, i.e., latitude and longitude, would generally show the place where the photo was taken. There are many online and offline tools to read the EXIF data from images. One command-line tool is `exiftool`. ExifTool is used to read and write metadata in various file types, such as JPEG images. The AttackBox already has `exiftool` installed; however, if you are using Kali Linux and don't have `exiftool` installed, you can install it using `sudo apt install libimage-exiftool-perl`. In the following terminal window, we executed `exiftool IMAGE.jpg` to read all the EXIF data embedded in this image.

```
root@tryhackme:~# exiftool IMAGE.jpg
[...]
GPS Position : 51 deg 31' 4.00" N, 0 deg 5' 48.30" W
[...]
```

If you take the above coordinates and search one of the online maps, you will learn more about this location. Searching [Microsoft Bing Maps](#)(opens in new tab) or [Google Maps](#)(opens in new tab) for `51 deg 30' 51.90" N, 0 deg 5' 38.73" W` reveals the street where the photo was taken. Note that for the search to work,

we had to replace `deg` with `°` and remove the extra white space. In other words, we typed `51°30'51.9"N 0°05'38.7"W` in the map search bar.

D. Incident Response Fundamentals

Task 1 - Introduction to Incident Response

Incident Response handles an incident from its start to end. From deploying security in several areas to prevent incidents to fighting with them, and minimizing their impact, incident response is a thorough guideline.

Task 2 - What are Incidents?

False positive: A security solution raised an alert on a high amount of data being transferred from one system to an external IP address. Upon analyzing this alert, the security team found that the subject system was undergoing a backup process to a cloud storage service, which caused this. This is known as a false positive.

True Positive: A security solution raised an alert on a phishing attempt on one of the organization's users. Upon analyzing this alert, the security team found that the email was a phishing email sent to this user to compromise the system. This is known as a true positive.

These true positive alerts are sometimes referred to as **Incidents**. Assuming the alert is now categorized as an incident, the next phase is to give a severity level to the incident.

Answer the questions below

What is triggered after an event or group of events point at a harmful activity?
Alert

If a security solution correctly identifies a harmful activity from a set of events, what type of alert is it? true positive

If a fire alarm is triggered by smoke after cooking, is it a true positive or a false positive? false positive

Task 3 - Types of Incidents

- **Malware Infections:** Malware is a malicious program that can damage a system, network, or application. The majority of incidents are associated with malware infections. There are different types of malware, each with a unique potential to cause damage. Malware infections are mostly caused by files that can be text, documents, executables, etc.
- **Security Breaches:** Security Breaches arise when an unauthorized person gets access to confidential data (something we don't want them to see or have). Security Breaches are of the utmost importance as many businesses rely on their confidential data, which must only be accessible to authorized personnel.
- **Data Leaks:** Data leaks are incidents in which confidential information of an individual or an organization is exposed to unauthorized entities. Many attackers use data leaks for reputational damage to their victims or use this technique to threaten their victims and get what they need from them. Unlike Security Breaches, data leaks can also be unintentionally caused by human errors or misconfigurations.
- **Insider Attacks:** Incidents from within an organization are known as insider attacks. Think about a disgruntled employee infecting the whole network through a USB on his last day. This is an example of an insider attack. Someone within your organization intentionally initiating an attack comes under this category. These attacks can be hazardous, as an insider always has greater access to resources than an outsider.
- **Denial Of Service Attacks:** Availability is one of the three pillars of cyber security. Defensive security solutions and people constantly find ways to protect information; they ensure that the data is available to the people simultaneously. This is because there is no point in protecting something that is unavailable to us. Denial of Service attacks, or DoS attacks, are incidents where the attacker floods a system/network/application with false requests, eventually making it unavailable to legitimate users. This happens due to the exhaustion of resources available to entertain the requests.

Answer the questions below

A user's system got compromised after downloading a file attachment from an email. What type of incident is this? malware infection

What type of incident aims to disrupt the availability of an application? Denial of service

Task 4 - Incident Response Process

SANS and NIST are popular organizations contributing to cyber security. SANS has offered various courses and certifications in cyber security, and NIST played its role in developing standards and guidelines for cyber security. Both SANS and NIST have quite similar incident response frameworks. The SANS incident Response framework has 6 phases, which can be called 'PICERL' to remember them easily.

Phase	Explanation	Example
Preparation	This is the first phase. The preparation phase includes building the necessary resources to handle an incident. These resources include developing incident response teams, having a proper incident response plan in place, and deploying necessary security solutions to combat the incidents.	Conducting awareness training for employees on phishing emails. Phishing emails are fraudulent emails sent by malicious attackers that can trick you into performing actions that can lead you to an incident.
Identification	The identification phase refers to looking for any abnormal behavior that may indicate an incident. This involves using various security solutions and techniques to monitor abnormal events.	The security team notices a huge amount of data being sent out from one of the hosts. Upon analysis, it was found to be compromised after a malicious file was downloaded from a phishing email attachment.
Containment	Once an incident has been identified, the next step	The Security team isolates the host from the network to minimize the impact and not

Phase	Explanation	Example
	should be to contain it. This means minimizing the impact of the attack. This is usually done by isolating the victim machine, disabling the compromised user accounts, etc.	allow the attacker to jump to other systems, leveraging the compromised host.
Eradication	This phase, as its name suggests, involves removing the threat from the attacked environment. The threat may be of any kind. The eradication phase will ensure the subject environment is clean, and now we can move to the recovery phase.	A deep malware scan was executed on the system to remove the malicious software from the host.
Recovery	The recovery phase is very important in this chain. It involves recovering the affected systems from backup or rebuilding them. The recovered systems are then tested and are ready to use.	The compromised host was re-configured, and the exfiltrated data was restored from the backup.
Lessons Learned	This is also an important part of the incident response lifecycle. Gaps in the detection and analysis of the incident are identified and documented, helping to improve the overall process in future incidents.	Conducting a post-incident review meeting to analyze the incident's root cause and improve the security to prevent future attacks.

SANS	NIST
Preparation	Preparation
Identification	Detection and Analysis
Containment	Containment, Eradication, and Recovery
Eradication	
Recovery	
Lessons Learned	Post Incident Activity

Answer the questions below

The Security team disables a machine's internet connection after an incident. Which phase of the SANS IR lifecycle is followed here? containment

Which phase of NIST corresponds with the lessons learned phase of the SANS IR lifecycle? Post Incident Activity

Task 5 - Incident Response Techniques

- **SIEM:** The Security Information and Event Management Solution (SIEM) collects all important logs in one centralized location and correlates them to identify incidents.
- **AV:** Antivirus (AV) detects known malicious programs in a system and regularly scans your system for these.
- **EDR:** Endpoint Detection and Response (EDR) is deployed on every system, protecting it against some advanced-level threats. This solution can also contain and eradicate the threat.

After incidents are identified, certain procedures must be followed, including investigating the extent of the attack, taking necessary actions to prevent further damage and eliminate it from the root. These steps may be different for different kinds of incidents. In this scenario, having step-by-step instructions to deal with each kind of incident helps you save a lot of time. These types of instructions are known as **Playbooks**. Playbooks are the guidelines for a comprehensive incident response.

Following is an example of a **Playbook** for an incident: Phishing Email

1. Notify all the stakeholders of the phishing email incident
2. Determine if the email was malicious by conducting header and body analysis of the email
3. Look for any attachments with the email and analyze them
4. Determine if anybody opened the attachments
5. Isolate the infected systems from the network
6. Block the email sender

Runbooks, on the other hand, are the detailed, step-by-step execution of specific steps during different incidents. These steps may vary depending on the resources available for investigation.

Answer the questions below

Step-by-step comprehensive guidelines for incident response are known as?
Playbooks

E. Logs Fundamentals

Task 1 - Introduction to Logs

Use Cases of Logs

Use Case	Description
Security Events Monitoring	Logs help us detect anomalous behavior when real-time monitoring is used.

Use Case	Description
Incident Investigation and Forensics	Logs are the traces of every kind of activity. It offers detailed information on what happened during the incident. The security team utilizes the logs to perform root cause analysis of incidents.
Troubleshooting	As the logs also record the errors in systems or applications, they can be used to diagnose issues and helpful in fixing them.
Performance Monitoring	Logs can also provide valuable insights into the performance of applications.
Auditing and Compliance	Logs play a major role in Auditing and Compliance, making it easier with its capability to establish a trail of different kinds of activities.

Where can we find the majority of attack traces in a digital system? Logs

Task 2 - Types of Logs

Log Type	Usage	Example
System Logs	The system logs can be helpful in troubleshooting running issues in the OS. These logs provide information on various operating system activities.	- System Startup and shutdown events- Driver Loading events- System Error events- Hardware events
Security Logs	The security logs help detect and investigate incidents. These logs provide information on the security-related activities in the system.	-Authentication events- Authorization events- Security Policy changes events- User Account changes events - Abnormal Activity events
Application Logs	The application logs contain specific events related to the application. Any interactive or non-interactive activity happening inside the application will be logged here.	- User Interaction events- Application Changes events- Application Update events- Application Error events
Audit Logs	The Audit logs provide detailed information on the system changes and user events. These logs are helpful for compliance requirements and can play a vital role in security monitoring as well.	- Data Access events- System Change events- User Activity events- Policy Enforcement events

Log Type	Usage	Example
Network Logs	Network logs provide information on the network's outgoing and incoming traffic. They play crucial roles in troubleshooting network issues and can also be handy during incident investigations.	- Incoming Network Traffic events- Outgoing Network Traffic events- Network Connection Logs - Network Firewall Logs
Access Logs	The Access logs provide detailed information about the access to different resources. These resources can be of different types, providing us with information on their access.	- Webserver Access Logs- Database Access Logs - Application Access Logs- API Access Logs

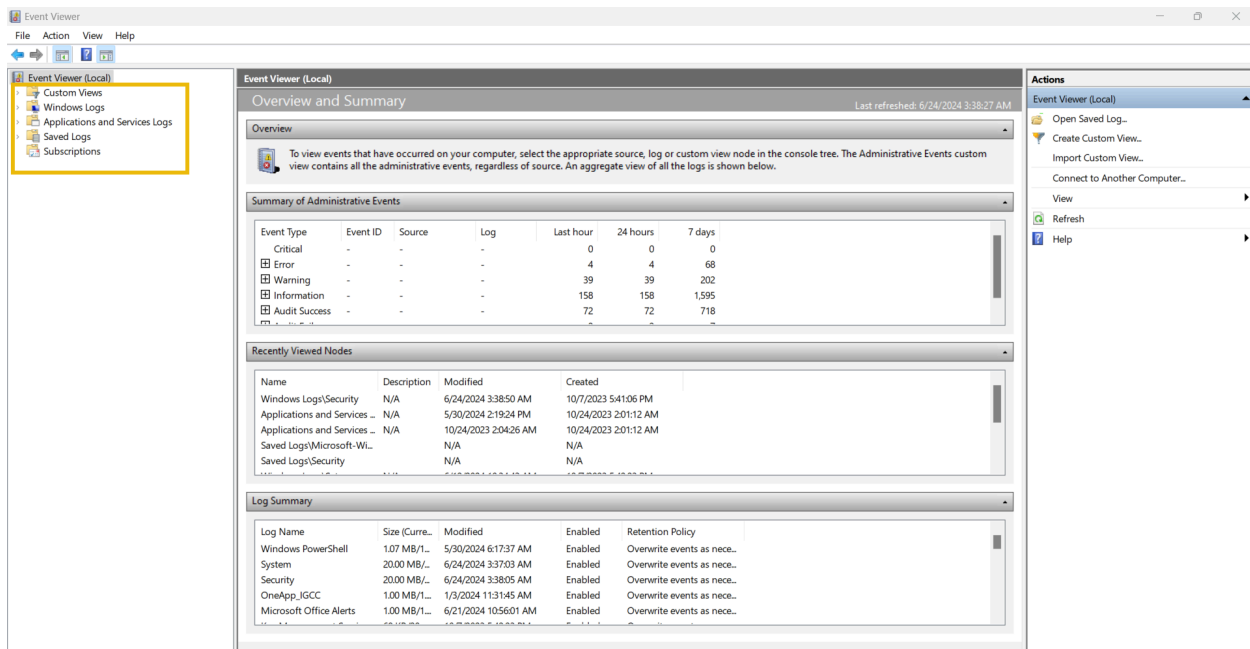
Answer the questions below

Which type of logs contain information regarding the incoming and outgoing traffic in the network? Network Logs

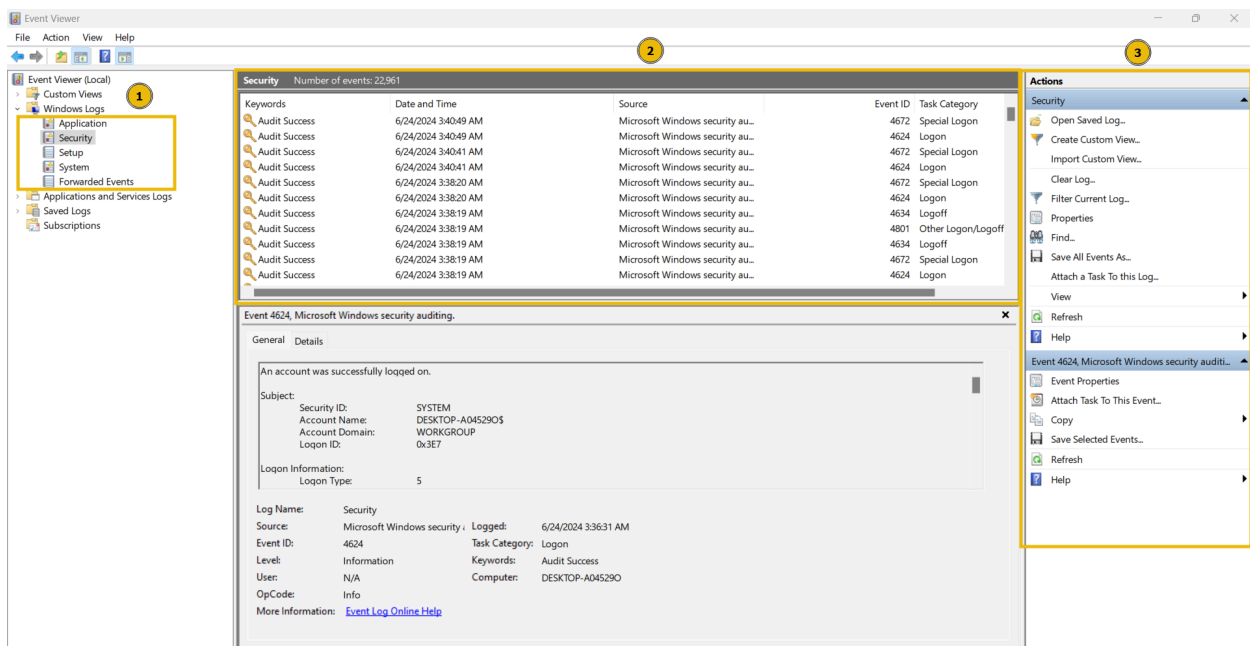
Which type of logs contain the authentication and authorization events?
Security Logs

Task 3 - Windows Event Logs Analysis

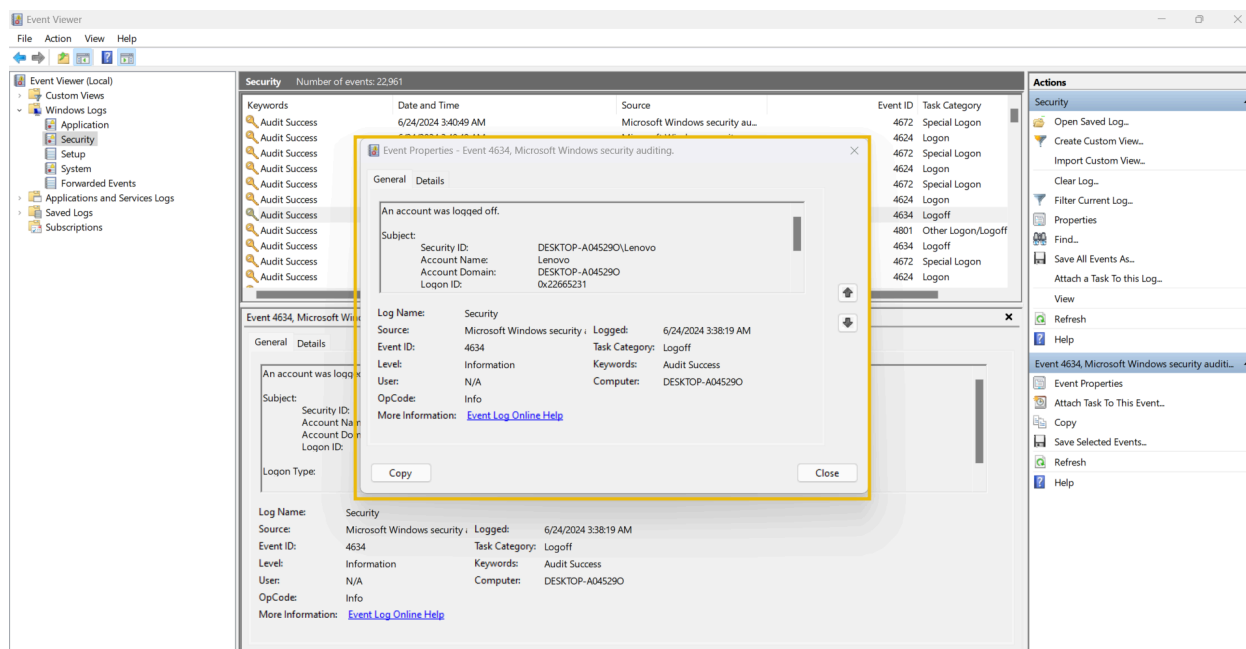
- **Application:** There are many applications running on the operating system. Any information related to those applications is logged into this file. This information includes errors, warnings, compatibility issues, etc.
- **System:** The operating system itself has different running operations. Any information related to these operations is logged in the System log file. This information includes driver issues, hardware issues, system startup and shutdown information, services information, etc.
- **Security:** This is the most important log file in Windows OS in terms of security. It logs all security-related activities, including user authentication, changes in user accounts, security policy changes, etc.



You can click 'Windows Logs' from the highlighted section to see the different types of logs we discussed at the beginning of this task.



Let's double-click on one of these logs to see its contents.



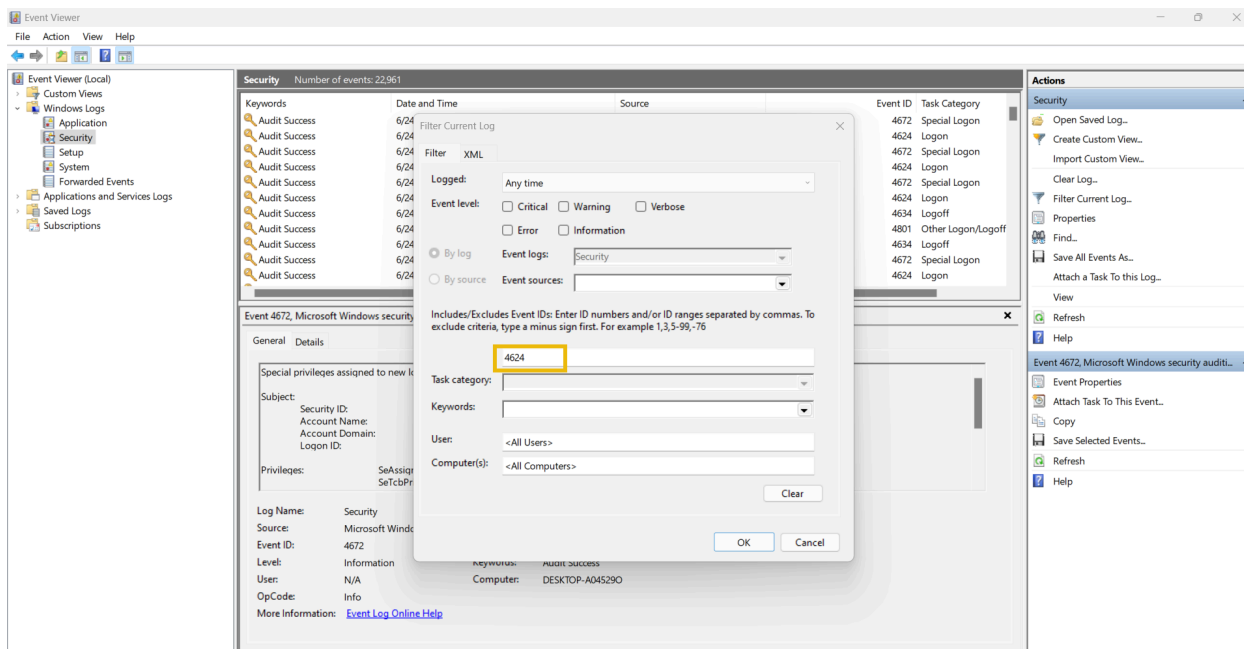
This is how a Windows event log looks. It has different fields. The major fields are discussed below:

- **Description:** This field has a detailed information of the activity.
- **Log Name:** The Log Name indicates the log file name.
- **Logged:** This field indicates the time of the activity.
- **Event ID:** Event IDs are unique identifiers for a specific activity.

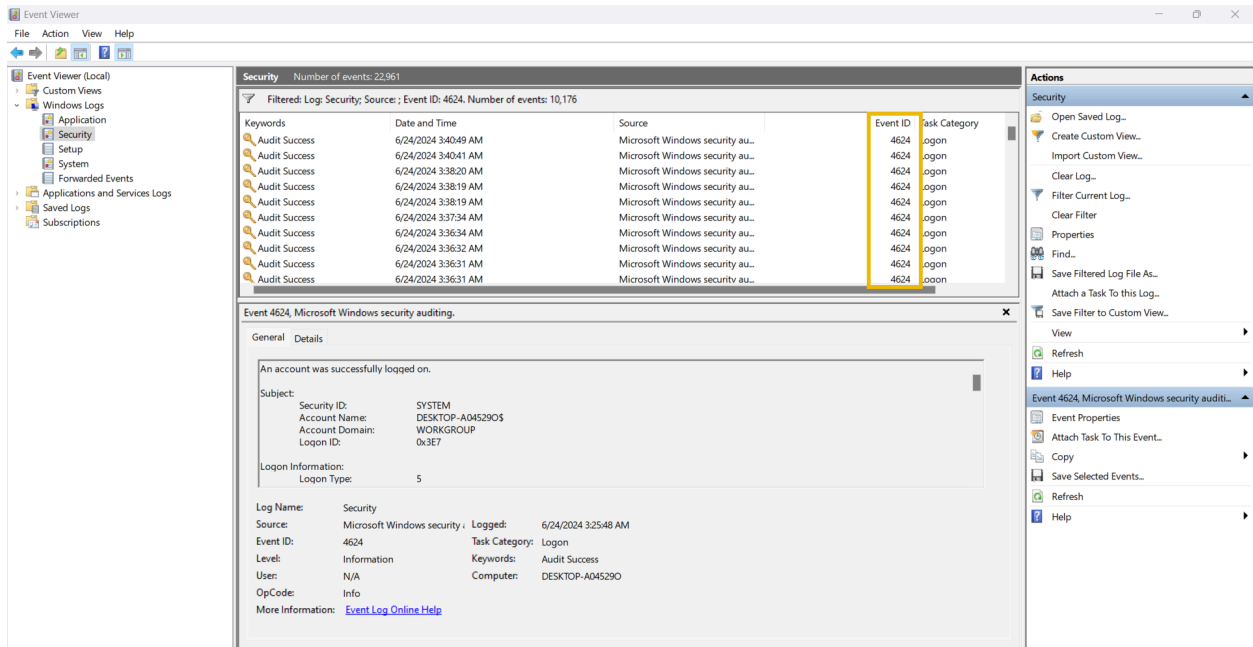
Numerous event IDs are available in Windows event logs. We can use these event IDs to search for any specific activity. For example, event ID 4624 uniquely identifies the activity of a successful login, so you only need to search for this event ID 4624 when investigating successful logins. Here is a table of some important Event IDs in Windows Operating System.

Event ID	Description
4624	A user account successfully logged in
4625	A user account failed to login
4634	A user account successfully logged off
4720	A user account was created
4724	An attempt was made to reset an account's password

Event ID	Description
4722	A user account was enabled
4725	A user account was disabled
4726	A user account was deleted



Once I hit the 'OK' button, I can see all the logs with the event ID: 4624. I can now view any of these logs by double-clicking them.



Task 4 - Web Server Access Logs Analysis

Following are the fields taken from a sample log from an Apache web server access log file which can be found in the directory: `/var/log/apache2/access.log`

- **IP Address:** "172.16.0.1" - The IP address of the user who made the request.
- **Timestamp:** "[06/Jun/2024:13:58:44]" - The time when the request was made to the website.
- **Request:** The request details.
 - **HTTP Method:** "GET" - Tells the website what action to be performed on the request.
 - **URL:** "/" - The requested resource.
- **Status Code:** "200" - The response from the server. Different numbers indicate different response results.
- **User-Agent:** "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_3) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36" - Information about the user's Operating System, browser, etc. when making the request.

We can perform manual log analysis by using some command line utilities in the Linux operating system. The following are some commands that can be useful during manual log analysis. `cat` is a popular utility for displaying the contents of a text file. We can use the `cat` command to display the contents of a log file, as they are typically in the text format.

```
root@kali$ cat access.log
172.16.0.1 - - [06/Jun/2024:13:58:44] "GET /products HTTP/1.1" 404 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"
10.0.0.1 - - [06/Jun/2024:13:57:44] "GET / HTTP/1.1" 404 "-" "Mozilla/5.0 (Macintosh; Intel Mac OS X 10_12_3) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"
192.168.1.1 - - [06/Jun/2024:13:56:44] "GET /about HTTP/1.1" 500 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"
```

Sometimes, we may need to combine two log files. The `cat` command-line utility can also be helpful in this case. We can combine the results of multiple files within one single file, as shown below.

```
root@kali$ cat access1.log access2.log > combined_access.log
```

`grep` is a very useful command line utility that allows you to search for strings and patterns inside a log file. For example, you may need to search if a specific IP address is present in your log file.

```
root@kali$ grep "192.168.1.1" access.log
192.168.1.1 - - [06/Jun/2024:13:56:44] "GET /about HTTP/1.1" 500 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"
192.168.1.1 - - [06/Jun/2024:13:53:44] "GET /products HTTP/1.1" 404 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"
```

```
1" 404 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWe  
bKit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/5  
37.36"  
192.168.1.1 - - [06/Jun/2024:13:46:44] "GET /about HTTP/1.1"  
200 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKi  
t/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.  
36"
```

The `less` command is helpful for handling multiple log files.

```
root@kali$ less access.log  
172.16.0.1 - - [06/Jun/2024:13:52:44] "GET /products HTTP/1.  
1" 404 "-" "Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWeb  
Kit/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/53  
7.36"  
10.0.0.1 - - [06/Jun/2024:13:48:44] "GET /about HTTP/1.1" 404  
-" "Mozilla/5.0 (Windows NT 6.1; Win64; x64) AppleWebKit/53  
7.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.36"  
192.168.1.1 - - [06/Jun/2024:13:46:44] "GET /about HTTP/1.1"  
200 "-" "Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKi  
t/537.36 (KHTML, like Gecko) Chrome/58.0.3029.110 Safari/537.  
36"  
:
```